

Access Control Policy

This policy defines the rules and procedures for managing access to Saudi EXIM Bank's information systems. It ensures that access is granted based on business need, least privilege, and role separation, while maintaining accountability, auditing, and protection of sensitive information..

G-R-C Ops

Version	Approved By	Owner	Date Last Updated	Review Frequency	Next Review	Comments
1.0	Board of Directors	CISO	-	Every 6 months	1 st – July – 2026	

Contents

Policy Purpose	2
Policy Scope	2
Policy Statements	2
1. Logical Access Control Requirements	2
1.1 Access Authorization	2
1.2 Least Privilege and Need-to-Know	2
1.3 Segregation of Duties	2
1.4 Account Management.....	2
1.5 Authentication and Session Control.....	3
1.6 Monitoring and Logging	3
1.7 Remote, Wireless, and Mobile Access	3
1.8 Third-Party and External Access	3
2. Physical Access Control Requirements	3
2.1 Facility Access Control	3
2.2 Restricted Areas	3
2.3 Visitor Management.....	3
2.4 Physical Access Reviews	3
2.5 Protection of Equipment	3
2.6 Monitoring and Surveillance	4
Compliance	4
Policy Exceptions	4
Roles and Responsibilities	4
Date Issued/Date Reviewed.....	4

Policy Purpose

The purpose of this policy is to establish governance requirements for logical and physical access control to Saudi EXIM Bank information systems, ensuring protection of confidentiality, integrity, and availability in accordance with regulatory and organizational requirements.

Policy Scope

This policy applies to:

- All employees
- Contractors and consultants
- Third-party service providers
- Temporary staff
- Visitors
- All information systems, applications, infrastructure, cloud services
- All physical facilities including offices, branches, data centers, and restricted areas.

Policy Statements

Saudi EXIM Bank shall implement and maintain a formal, risk-based access control framework governing both logical and physical access.

Access shall be granted only when justified by business need and authorized by designated owners.

1. Logical Access Control Requirements

1.1 Access Authorization

- 1.1.1 Access to systems and data is granted only upon documented approval from authorized system or data owners.
- 1.1.2 Access rights are based on business need and job responsibilities.

1.2 Least Privilege and Need-to-Know

- 1.2.1 Users are granted the minimum level of access required to perform assigned duties.
- 1.2.2 Privileged access is strictly limited, approved, and monitored.

1.3 Segregation of Duties

- 1.3.1 Incompatible duties are identified and separated to reduce the risk of fraud, misuse, or error.
- 1.3.2 Conflicting access rights shall not be assigned without documented risk assessment and compensating controls.

1.4 Account Management

- 1.4.1 All user accounts must be uniquely identifiable.
- 1.4.2 Shared or generic accounts are prohibited unless formally approved and justified.
- 1.4.3 Access rights shall be reviewed periodically and revoked upon termination, role change, or contract expiration.

1.5 Authentication and Session Control

- 1.5.1 Strong authentication mechanisms shall be implemented in accordance with Bank security standards.
- 1.5.2 Inactive sessions shall be automatically locked or terminated after defined time periods.

1.6 Monitoring and Logging

- 1.6.1 Access activities, especially privileged actions, shall be logged and subject to monitoring and audit.
- 1.6.2 Unauthorized access attempts shall be detected and addressed promptly.

1.7 Remote, Wireless, and Mobile Access

- 1.7.1 Remote and wireless access must use approved secure communication mechanisms.
- 1.7.2 Mobile device access shall comply with Bank encryption and device security requirements.

1.8 Third-Party and External Access

- 1.8.1 Access from external systems or third parties shall require formal agreements, risk assessment, and security control verification.
- 1.8.2 Third-party access shall be limited to the scope necessary for contractual obligations.

2. Physical Access Control Requirements

Saudi EXIM Bank shall protect facilities and physical assets from unauthorized access, damage, and interference.

2.1 Facility Access Control

- 2.1.1 Physical access to offices, branches, and restricted areas shall be controlled through approved mechanisms (e.g., access badges, biometric systems, security personnel).
- 2.1.2 Access rights to physical facilities shall be formally authorized and documented.

2.2 Restricted Areas

- 2.2.1 Data centers, server rooms, network rooms, and archive areas shall be classified as restricted zones.
- 2.2.2 Access to restricted areas shall be limited to authorized personnel only.
- 2.2.3 Access logs shall be maintained and periodically reviewed.

2.3 Visitor Management

- 2.3.1 Visitors must be registered, identified, and escorted in restricted areas.
- 2.3.2 Visitor access shall be temporary and documented.

2.4 Physical Access Reviews

- 2.4.1 Physical access rights shall be reviewed periodically and revoked immediately upon termination or role change.

2.5 Protection of Equipment

- 2.5.1 Critical information processing facilities shall be protected against unauthorized removal, tampering, or damage.
- 2.5.2 Secure disposal procedures shall apply to physical media and equipment containing sensitive information.

2.6 Monitoring and Surveillance

- 2.6.1 Physical access points to sensitive areas shall be monitored through appropriate surveillance and logging mechanisms.

Compliance

Compliance with this policy is mandatory.

Violations may result in disciplinary action, termination of employment or contract, and legal consequences where applicable.

Compliance shall be subject to internal audit and regulatory review.

Policy Exceptions

Exceptions must be approved by the CISO and CIO. Requests must detail the scope, justification, risk assessment, mitigation measures, and timeline for achieving compliance.

Roles and Responsibilities

Role	Responsibility
Board of Directors	Provides oversight and approves the policy
CISO	Ensures policy implementation and compliance oversight.
System Owners	Approve and review user access to their systems.
HR Department	Notify IT of joiners, movers, and leavers.
IT Operations	Implement technical controls and enforce access configurations.
Employees and User	Comply with access control requirements

Date Issued/Date Reviewed

This policy must be reviewed at least annually or whenever there are changes to organizational procedures or regulatory requirements.

Date Issued:	19 th – 02 – 2026
Date Reviewed:	23 th – 02 – 2026